00208

Eu

Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Specialized in Cyber Security

Final Examination
Year 3, Semester 1&2 (2026)

IE3032 – Network Security

Duration: 2 Hours

May 2026

Instructions to Candidates:

- 10 minutes of reading time is given to students
- This paper has 4 Questions.
- Answer all questions in the booklet given.
- The total mark for the paper is 100.
- This paper contains 7 pages, including the cover page.
- One single sided A4 paper can be brought into the exam hall

Question 01 Network Attacks and Security [25 marks]

a. Explain how the terms Threat Actor, Asset, Vulnerability, Attack, and Impact are interconnected within a network-security incident lifecycle. Your answer should define each term, explain their sequential relationships, and include one brief, generic example illustrating the chain.

(7 marks)

b. For each scenario, identify the threat actor (internal/external), the targeted asset, the vulnerability exploited, and one most effective mitigation.

i. A contractor accesses the management subnet due to incorrect routing and retrieves switch configuration backups.
ii. A malicious group uses compromised IoT devices to overwhelm an outdated DNS server with bogus queries.

(8 marks)

c. Write the Cisco IOS commands to:

i. Enable port security on ports Fa0/3 and Fa0/4
ii. Set max MACs to 2
iii. Set on violation to restrict the ports
iv. Disable unused ports Fa0/5–Fa0/24 and Gi0/1–Gi0/2

(5 marks)

d. Write the Cisco IOS commands to:

i. Enable DHCP snooping globally
ii. Trust VLAN 10
iii. Enable snooping on Fa0/15–Fa0/16
iv. Apply rate limit of 15 packets/sec on Fa0/1

(5 marks)

Question 02 ACL and Firewalls [25 marks]

a. A financial services company plans to deploy a new customer-facing online payment portal. The application allows customers to initiate transactions, check account balances, and submit service requests. The company's internal network also hosts multiple back-office systems including authentication servers, and transaction-verification systems. The organisation must protect the Internet-accessible application while ensuring that internal network segments remain isolated and tightly controlled.

i. Analyse and describe the strengths of the following security solutions in the context of this deployment, focusing on what each firewall type provides:

- Zone-Based Firewall (ZBFW)
- Next-Generation Firewall (NGFW)
- API / Application-Layer Gateway Firewall (ALGF)

(6 marks)

ii. As the network engineer, evaluate the organisation's requirements and recommend one firewall type that best meets the combined needs of external application protection, internal segmentation, and traffic visibility. Provide a justification supported by scenario-specific reasoning.

(6 marks)

b. You are required to configure a Zone-Based Policy Firewall on Router 2 according to the following requirements. Write the correct Cisco IOS commands:

i. Create a security zone named CAMPUS
ii. Create a security zone named WAN-EDGE
iii. Assign interface GigabitEthernet 0/0 to the CAMPUS zone and interface Serial 0/1/0 to the WAN-EDGE zone

(6 marks)

c. A central file repository stores encryption keys and transaction logs used by the payment portal. Only the Security Manager's workstation (10.5.50.10) and the Application Server (10.5.100.5) should be allowed to access this file repository at 10.5.200.20. All other traffic must be denied. The senior network administrator instructs you to configure access control on Router A and Router B.Write the appropriate commands to meet the following requirements:

i. Create a standard named ACL on Router A called SECURE-ACCESS
ii. Permit traffic from hosts 10.5.50.10 and 10.5.100.5
iii. Deny all other traffic attempting to reach the repository
iv. Apply the ACL inbound on interface GigabitEthernet 0/1
v. On Router B, create a numbered ACL (ACL 12) that denies any traffic targeting 10.5.200.0/24 from any source other than the two approved hosts

(7 marks)

Question 03 VPN and AAA [25 marks]

a. You are the security architect for an international logistics company that handles sensitive shipment and customer-tracking information. The company has recently deployed several regional distribution centers overseas, and many employees now work while travelling, frequently connecting from airports and hotels. Both the regional sites and the roaming employees must securely access internal systems.

i. Explain the functionality and differences between a site-to-site VPN and a remote-access VPN.
ii. Recommend the most suitable secure communication approach for connecting overseas distribution centers AND travelling employees. Justify your answer.

(6 marks)

b. A small engineering firm operates three branch offices, each with a limited number of routers and switches. The branches rely on unreliable WAN connections, and management is concerned that if the WAN link goes down, administrators might lose access to critical network devices. The network addressing for this configuration is provided below:

Device	Interface	IP Address	Subnet Mask	Default Gateway	Switch Port
R5	G0/0	172.20.10.1	255.255.255.0	N/A	SW1 F0/3
R5	S0/0/0 (DCE)	10.5.5.2	255.255.255.252	N/A	N/A
R6	G0/1	172.20.20.1	255.255.255.0	N/A	SW2 F0/10
R6	S0/0/0	10.5.5.1	255.255.255.252	N/A	N/A

R6	S0/0/1 (DCE)	10.6.6.1	255.255.255.252	N/A	N/A
R7	G0/0	172.20.30.1	255.255.255.0	N/A	SW3 F0/7
R7	S0/0/1	10.6.6.2	255.255.255.252	N/A	N/A
TACACS + Server	NIC	172.20.20.50	255.255.255.0	172.20.20.1	SW2 F0/15
RADIUS Server	NIC	172.20.30.60	255.255.255.0	172.20.30.1	SW3 F0/12
Admin-PC	NIC	172.20.10.25	255.255.255.0	172.20.10.1	SW1 F0/4

Using the above addressing, write the COMPLETE Cisco IOS commands necessary to:

i. Create a local backup account on R6 with username NetAdmin and secret password engPwd11.
ii. Configure the TACACS+ server IP on R6 with key tacLocal44.
iii. Configure AAA login authentication for console access on R6.
iv. Configure the RADIUS server IP on R7 with key radLocal99.
v. Set the line console to use the defined AAA authentication method.

(9 marks)

c. The company must now choose between local AAA and server-based AAA for administrator authentication at each branch office.

i. Analyse whether the company should use local AAA or server-based AAA for branch devices.
ii. List the advantages and disadvantages of each method, and justify why your recommendation improves security.

(5 marks)

d. A multinational financial-services company reported that several employees attempting to log in to the company's secure portal were redirected to a fake login page — despite entering the correct website address. Some users observed that the page loaded unusually slowly, and forensic analysis revealed that attackers successfully harvested employee login credentials. Investigators believe the attackers manipulated the way employee devices resolved the company's domain information.

i. Identify the type of attack that likely occurred and explain how it works.
ii. As the network security administrator, describe two practical steps you would implement to prevent this type of attack in future.

(5 marks)

Question 04 Network Defense [25 marks]

a. You have been hired as a **lead cybersecurity engineer** at a company that recently experienced several serious security incidents. Senior management has requested a **formal threat analysis**, and you have been provided with short summaries from three separate investigations. For **each scenario**, you must:

- Identify the type of attack that occurred, and
- Recommend the most appropriate mitigation, with justification.

(9 marks)

i. Over the past week, several employees reported that when attempting to connect to the company's internal Wi-Fi, their devices automatically connected to a network using the same SSID, but with weaker encryption. Network logs later showed that sensitive user traffic had been intercepted.

ii. A developer discovered that files stored in a shared project directory had been silently modified. Investigation of server logs showed that an external attacker had uploaded altered files through an unsecured input interface, by injecting malicious commands into fields that were not validated.

iii. Users reported extremely slow file downloads from the company's public website. Further monitoring showed that the server was being overwhelmed with high-volume ICMP traffic, saturating its processing capacity and degrading service performance.

b. Following the incidents in Question 04 (a), senior management has mandated the creation of new policy documents to strengthen the organisation's security governance, Disaster Recovery (DR), and Business Continuity Planning (BCP) posture. These documents must directly address the weaknesses revealed by the recent attacks. Identify TWO key security policy documents that should be created. For each document:

i. Describe its purpose in supporting DR and BCP
ii. Explain the main areas the policy should cover
iii. Write two specific rules that must be included

(8 marks)

c. The company is undertaking a major upgrade of its headquarters network. Currently, the HQ relies on a basic router with a built-in firewall. Soon, the company will deploy a cloud-connected analytics platform and host internal HR and Finance servers on-premise. The analytics platform must be reachable from the internet, while the HR and Finance servers should only be accessible internally. The company will also adopt multiple VLANs for departmental segmentation, and sensitive VLANs (e.g., Finance) will require stronger inspection and filtering.

i. Using a diagram, illustrate the network architecture you recommend for the upgraded HQ. Your diagram must clearly show:

- A secured perimeter layer

- A DMZ segment hosting the analytics platform
- Internal VLANs (including HR and Finance)
- A filtering/inspection layer controlling inter-VLAN communication

(4 marks)

ii. Recommend the type of firewall architecture best suited for this upgraded environment and justify your choice.

(4 marks)

******